FICHE 11 - ENCADRER LES DÉVELOPPEMENTS INFORMATIQUES

Intégrer la sécurité et la protection des données personnelles au plus tôt dans les projets.

La protection des données personnelles doit être intégrée dans le cycle de développement informatique dès la phase de conception et pour les configurations par défaut afin d'offrir aux personnes concernées une meilleure maîtrise de leurs données et de limiter les erreurs, pertes, modifications non autorisées, ou mauvais usages de celles-ci dans les applications.

Les précautions élémentaires

- **Intégrer la protection des données, y compris ses exigences en termes de sécurité des données, dès la conception** de l'application ou du service. Ces exigences peuvent se traduire par divers choix d'architecture (décentralisée ou centralisée), de fonctionnalités (ex. : anonymisation à bref délai, minimisation des données), de technologies (ex. : chiffrement des communications), etc.
- Utiliser des composants (ex. : bibliothèques) et outils **sécurisés et reconnus par la communauté**.
- Mettre en œuvre des mesures contre les attaques courantes qui visent les bases de données (ex. : injections de code SQL, scripts).
- **Pour tout développement à destination du grand public, mener une réflexion sur les paramètres influant sur le respect de la vie privée**, et notamment sur le paramétrage par défaut.
- **Éviter le recours à des zones de texte libre ou de commentaires**, sources de collecte de données personnelles supplémentaires non nécessaires ou disproportionnées.
- **Réaliser des tests complets** (ex. : unitaires, d'intégration, fonctionnels, de sécurité) avant la mise à disposition ou la mise à jour d'un produit. Lors d'une mise à jour, s'assurer que les tests utilisés sont toujours adaptés.
- Effectuer les développements informatiques et les tests dans un environnement informatique distinct de celui de la production (ex. : sur des ordinateurs ou des machines virtuelles différents) et sur des données fictives ou anonymisées.
- **Veiller à l'absence de secrets (d'authentification ou de chiffrement)** lors du dépôt de code dans un outil de gestion de versions (ex. : Git ou svn). **Changer les secrets lors du passage en production.**
- **Effectuer un test de non-régression et/ou une revue de code avant tout passage en production d'une mise à jour** pour éviter l'apparition de sources de violation de données personnelles.

Ce qu'il ne faut pas faire

- Utiliser des données personnelles réelles pour les phases de développement et de test. Des jeux fictifs doivent être utilisés autant que possible.
- Développer une application puis réfléchir dans un second temps aux mesures de sécurité ou de protection des données personnelles à mettre en place.